

# Security in Software Applications

Secure Software Development

Models/Methods



SAPIENZA  
UNIVERSITÀ DI ROMA

Daniele Friolo

[friolo@di.uniroma1.it](mailto:friolo@di.uniroma1.it)

<https://danielefriolo.github.io>

# Objective

---

- Understand/Familiarize with various process models for secure software development and assurance
  - Capability Maturity Models
    - CMMI, iCMM, SSE-CMM
    - TSP
  - Secure software development life cycle models

# Process Models

---

## ■ Secure Process

- Set of activities performed to develop, maintain, and deliver a secure software solution
- Activities could be concurrent or iterative

## ■ Process model

- provides a reference set of best practices that can be used for both
  - process improvement and process assessment
- defines the characteristics of processes
- usually has an architecture or a structure

# Process Models

---

## ■ Process Models

- Identify technical and management practices
  - good software engineering practices to manage and build software
- Establishes
  - common measures of organizational processes throughout the software development lifecycle (SDLC).
- But ... no guarantees the product is bug free

# Process Models

---

- Typically also have a *capability* or *maturity* dimension used for
  - assessment and evaluation purposes.
- Assessments, evaluations, appraisals includes
  - **comparison** of a **process being practiced** to a reference process model or standard
  - **understanding** process capability in order to improve processes
  - **determining** if the **processes being practiced** are
    - adequately specified, designed, and implemented

# Software Development Life Cycle (SDLC)

---

- A survey of existing processes, process models, and standards seems to identify the following **four SDLC focus areas** for secure software development
  - Security Engineering Activities
  - Security Assurance
  - Security Organizational and Project Management (focused) Activities
  - Security Risk Identification and Management Activities

## ■ Security Engineering Activities

### ■ activities needed to engineer a secure solution.

security requirements elicitation and definition, secure design based on design principles for security, use of static analysis tools, reviews and inspections, security testing, etc..

## ■ Security Assurance Activities

verification, validation, expert review, artifact review, and evaluations.

## ■ Security Focused Activities

### ■ Organizational management

- organizational policies, senior management sponsorship and oversight, establishing organizational roles, ....

### ■ Project management

- project planning and tracking,
- resource allocation and usage

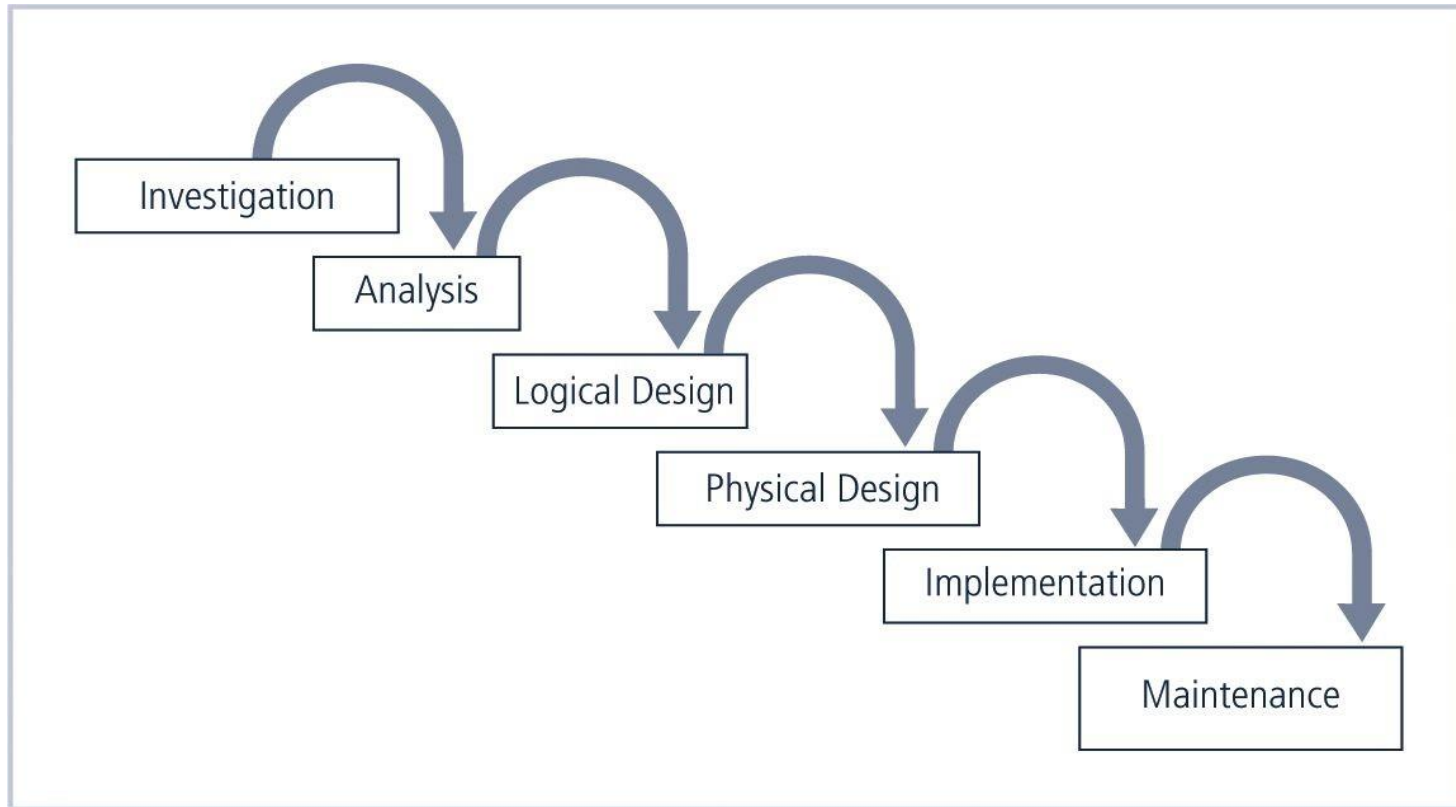
## ■ Security Risk Identification and Management Activities

- Cost-based Risk analysis
- Risk mitigation ..



# System DLC

---



## Capability Maturity Models (CMM)

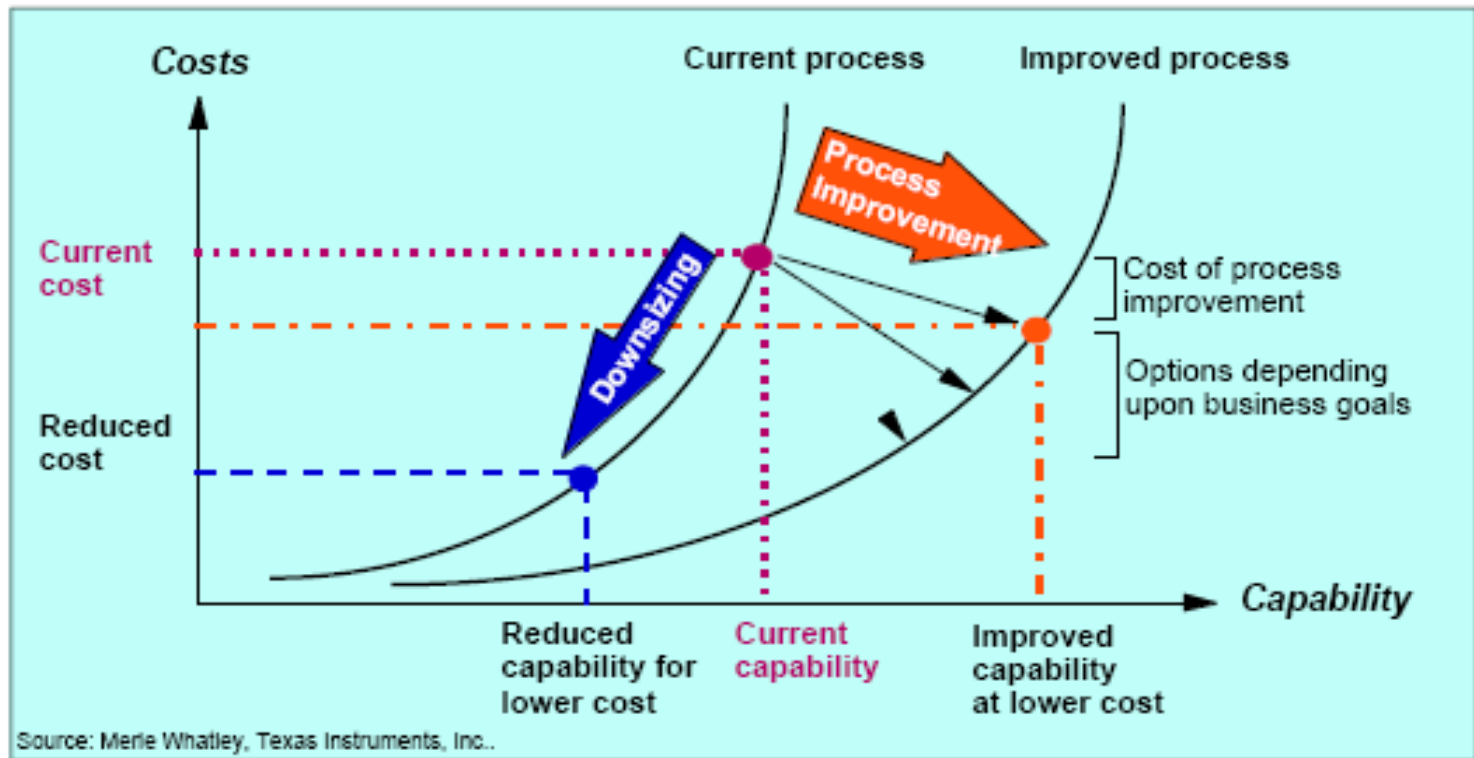
---

- Provides reference model of mature practices
- Helps identify the potential areas of improvement
- Provides goal-level definition and key attributes for specific processes
- **No operational guidance !!**
- *Focuses on/Defines process characteristics*

## ■ Three CMMs

- Capability Maturity Model Integration® (CMMI®),
- The integrated Capability Maturity Model (iCMM),
- Systems Security Engineering Capability Maturity Model (SSE-CMM)
  - Specifically to develop secure systems

# Why CMM?

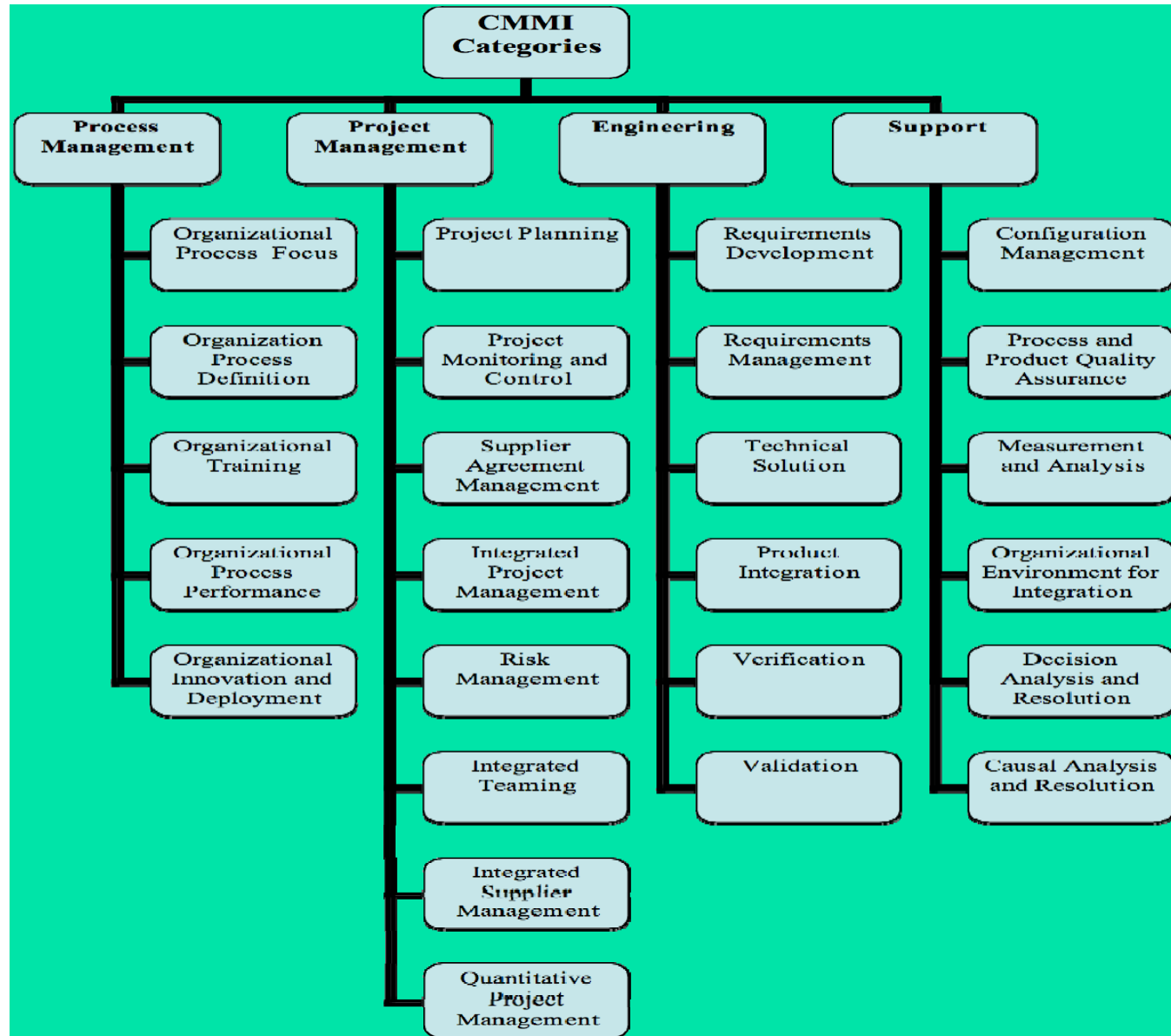


Source: [http://www.secat.com/download/locked\\_pdf/SSEovrw\\_lkd.pdf](http://www.secat.com/download/locked_pdf/SSEovrw_lkd.pdf)

# CMMI

---

- CMM Integration (CMMI) provides
  - the latest best practices related to
    - development, maintenance, and acquisition,
  - it includes
    - Mechanisms to improve processes and
    - Criteria for evaluating process capability and process maturity.
- As of Dec 2005, the SEI reports
  - 1106 organizations and 4771 projects have reported results from CMMI-based appraisals
- its predecessor, the software CMM (SW-CMM)
  - Since 80s – Dec, 2005
    - 3049 Organizations + 16,540 projects

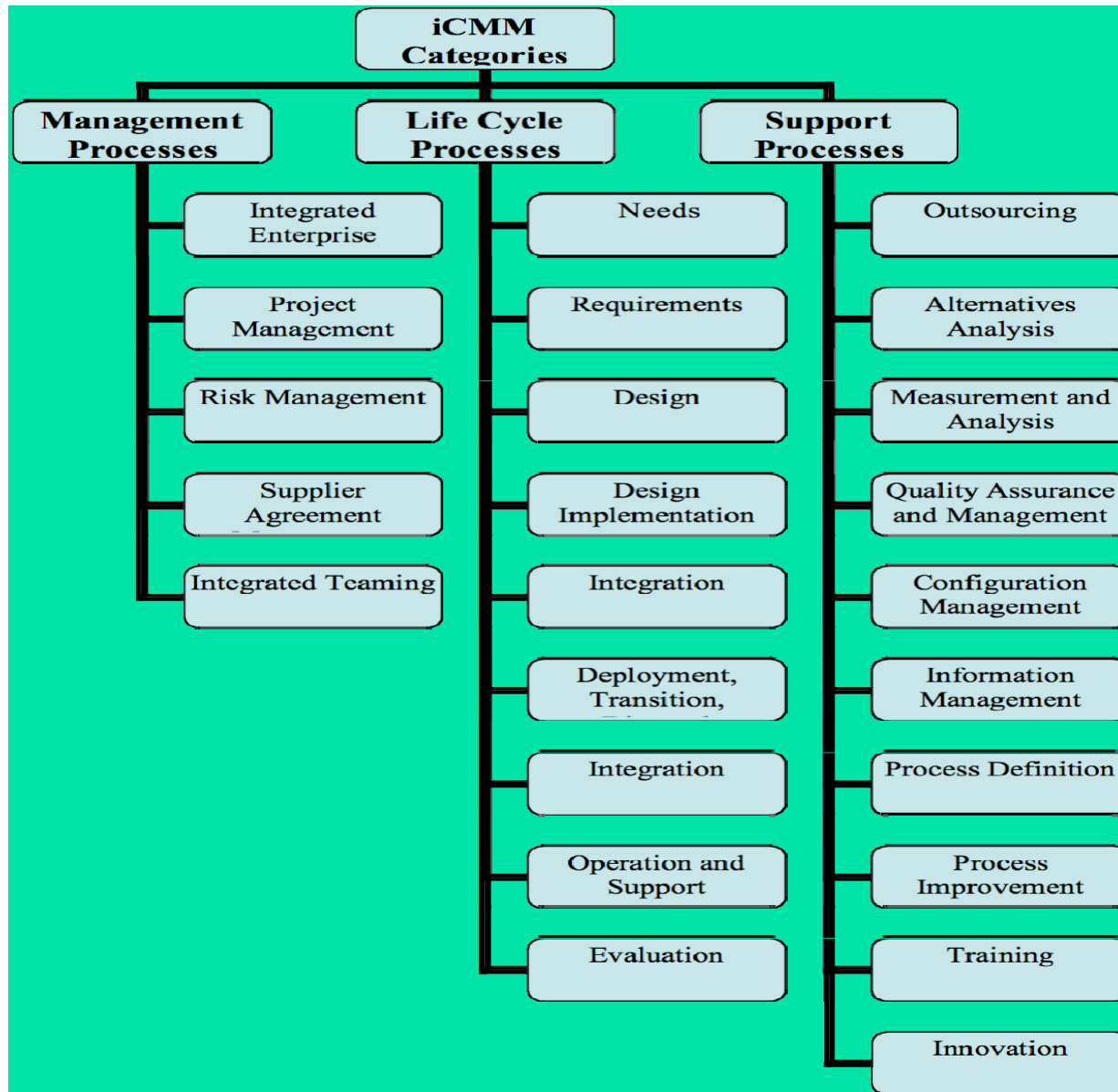


# Integrated CMM

---

- iCMM is widely used in the Federal Aviation Administration (FAA-iCMM)
  - Provides a single model for enterprise-wide improvement
- integrates the following standards and models:
  - ISO 9001:2000, EIA/IS 731,
  - Malcolm Baldrige National Quality Award and President's Quality Award criteria,
  - CMMI-SE/SW/IPPD and
  - CMMI-A, ISO/IEC TR 15504, ISO/IEC 12207, and ISO/IEC CD 15288.

# Integrated CMM





# Trusted CMM

---

## ■ Trusted CMM

- Early 1990 -Trusted Software Methodology (TSM)
- TSM defines trust levels
  - *Low* emphasizes resistance to unintentional vulnerabilities
  - *High* adding processes to counter malicious developers
- TSM was later harmonized with CMM
  - Not much in use

# Systems Security Engineering CMM

---

## ■ The SSE-CMM

- To improve and assess the **security engineering capability** of an organization
- provides a comprehensive framework for
  - **evaluating** security engineering practices against the generally accepted security engineering principles.
- provides a way to
  - **measure** and **improve** performance in the application of security engineering principles.

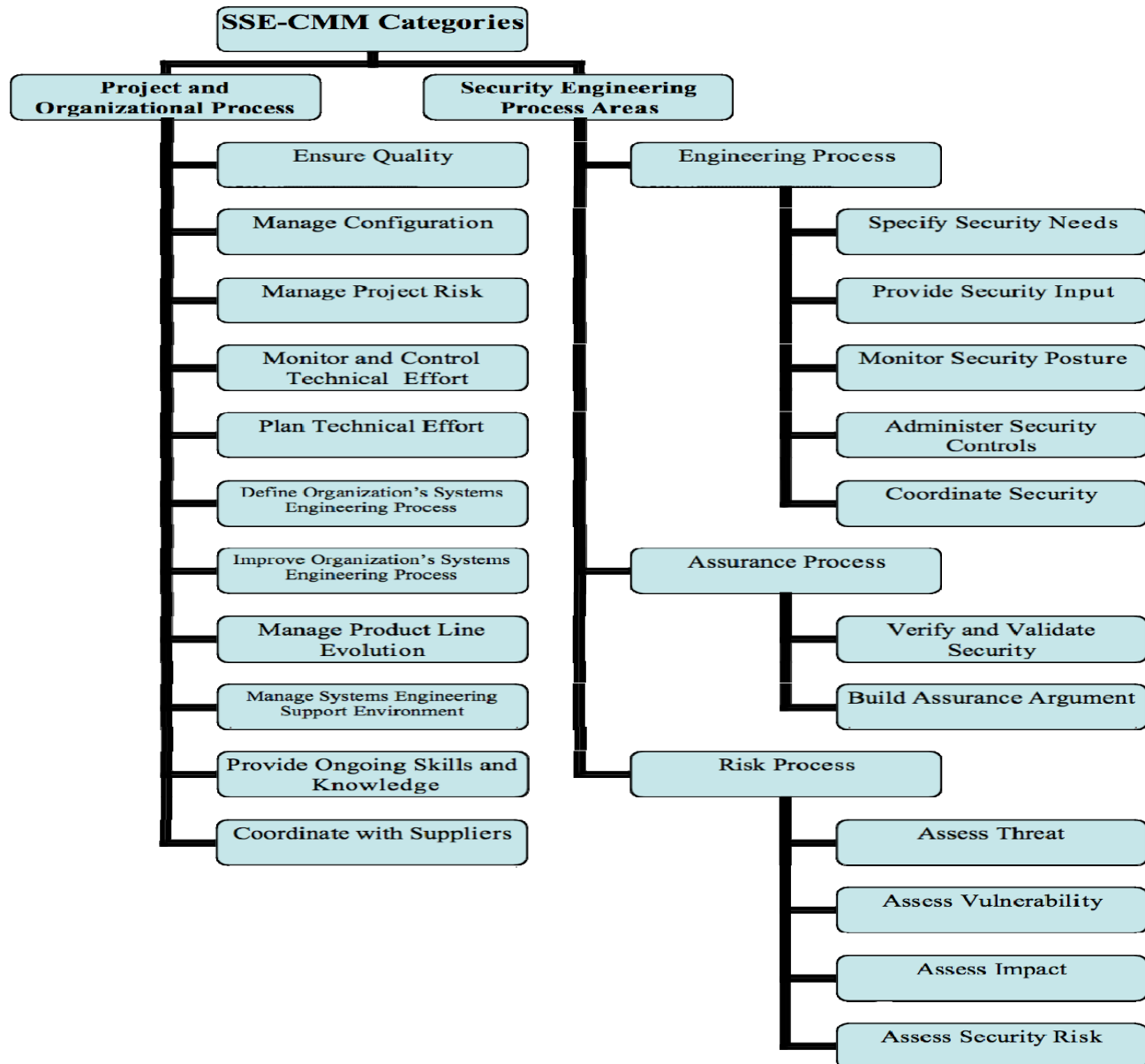
# SSE-CMM: ISO/IEC 21827

---

- Purpose for SSE-CMM
  - To fill the **lack of a comprehensive framework** for evaluating security engineering practices against the principles
- The SSE-CMM also
  - describes the essential characteristics of an organization's security engineering processes.

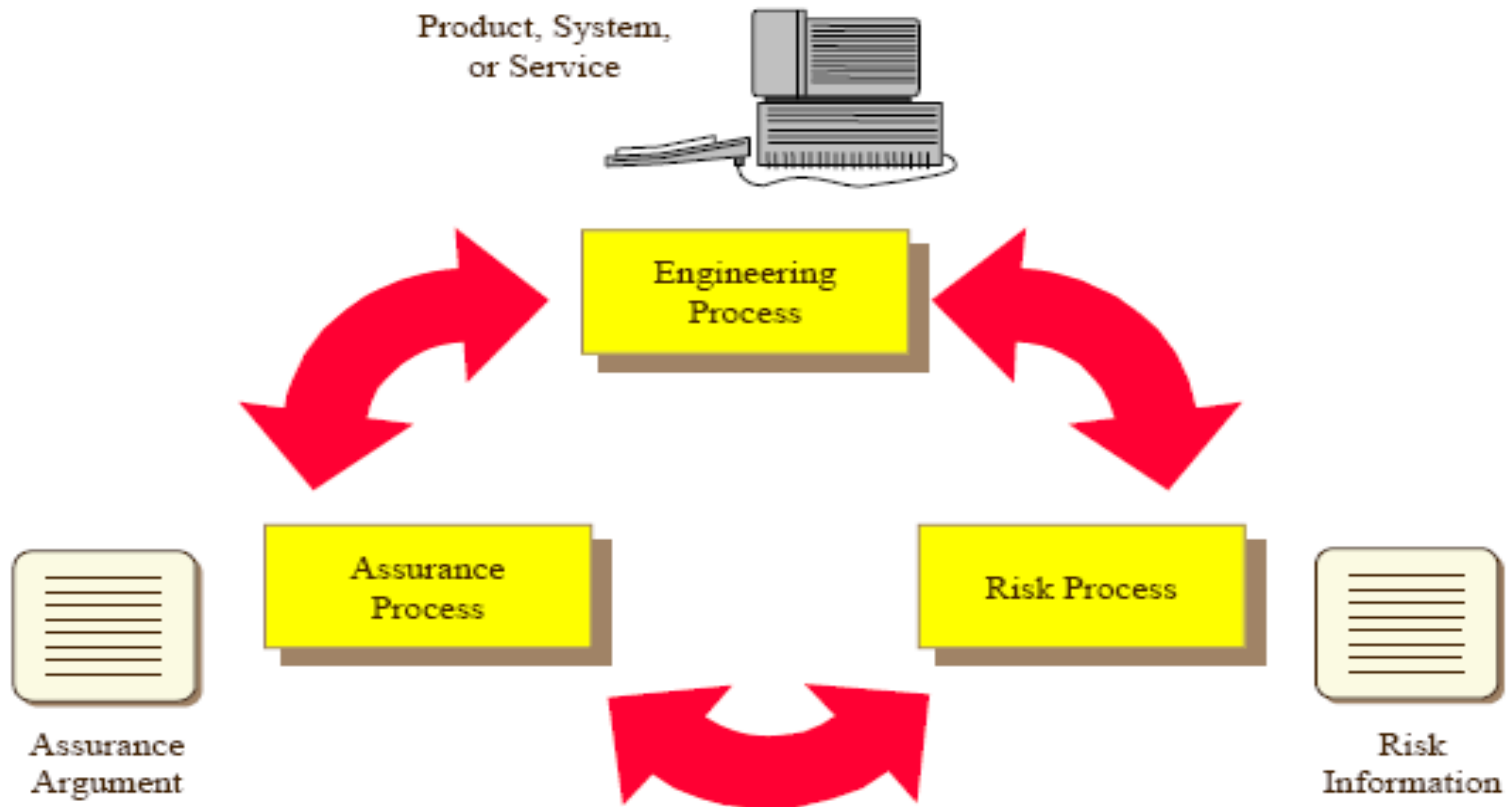
The SSE-CMM is now ISO/IEC 21827 standard (version 3 available)

# SSE-CMM



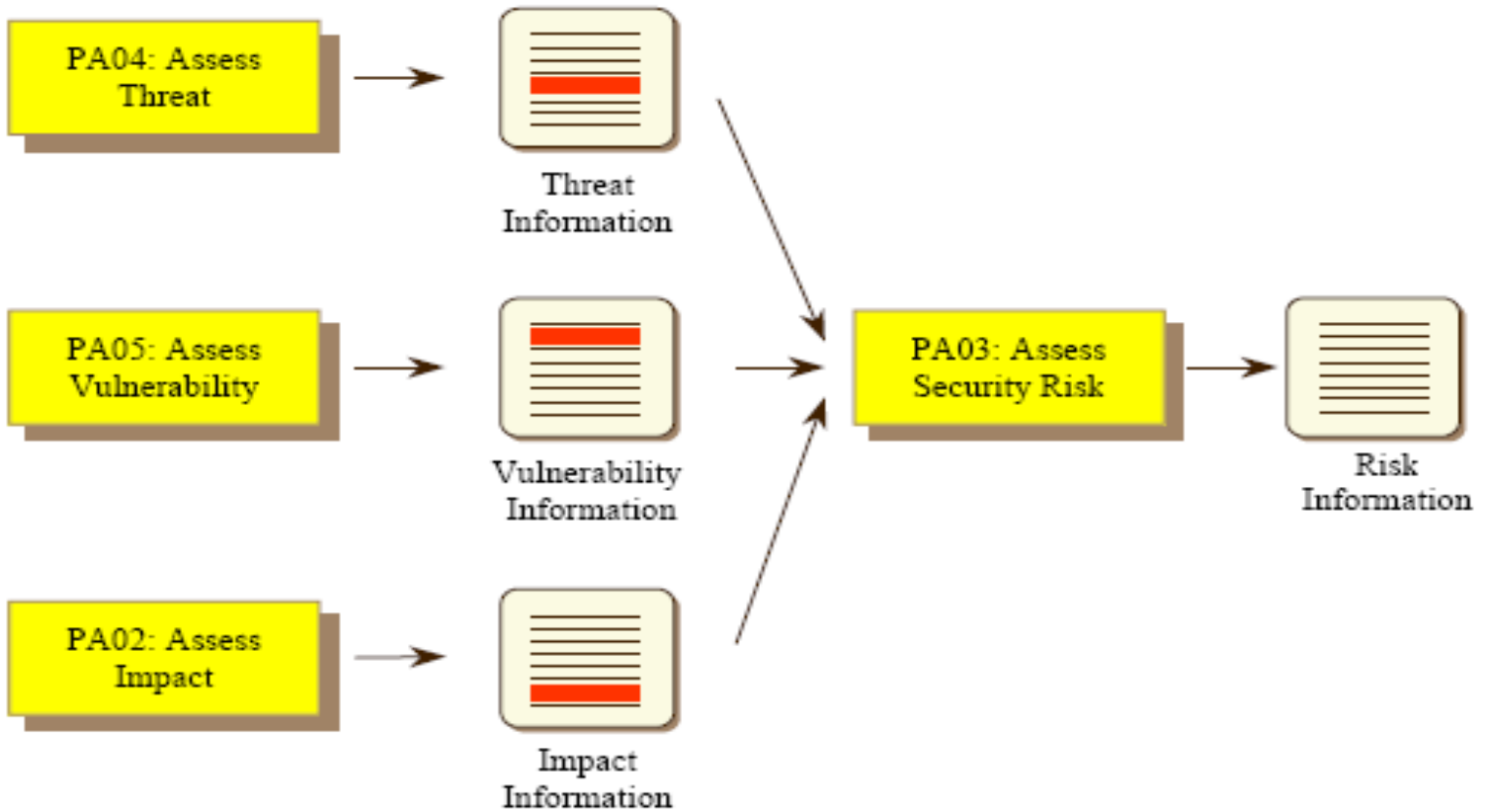
# Security Engineering Process

---



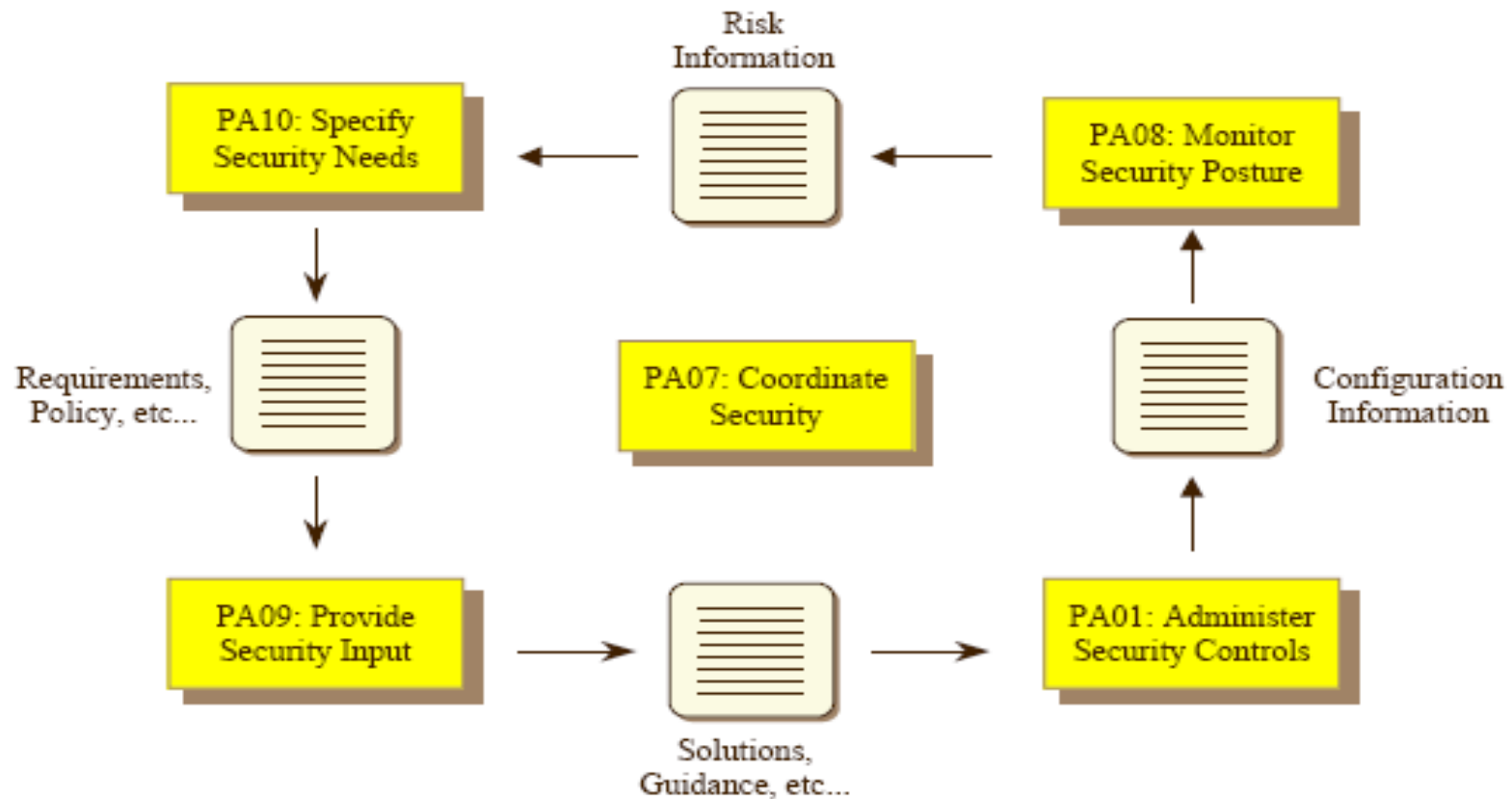
# Security Risk Process

---



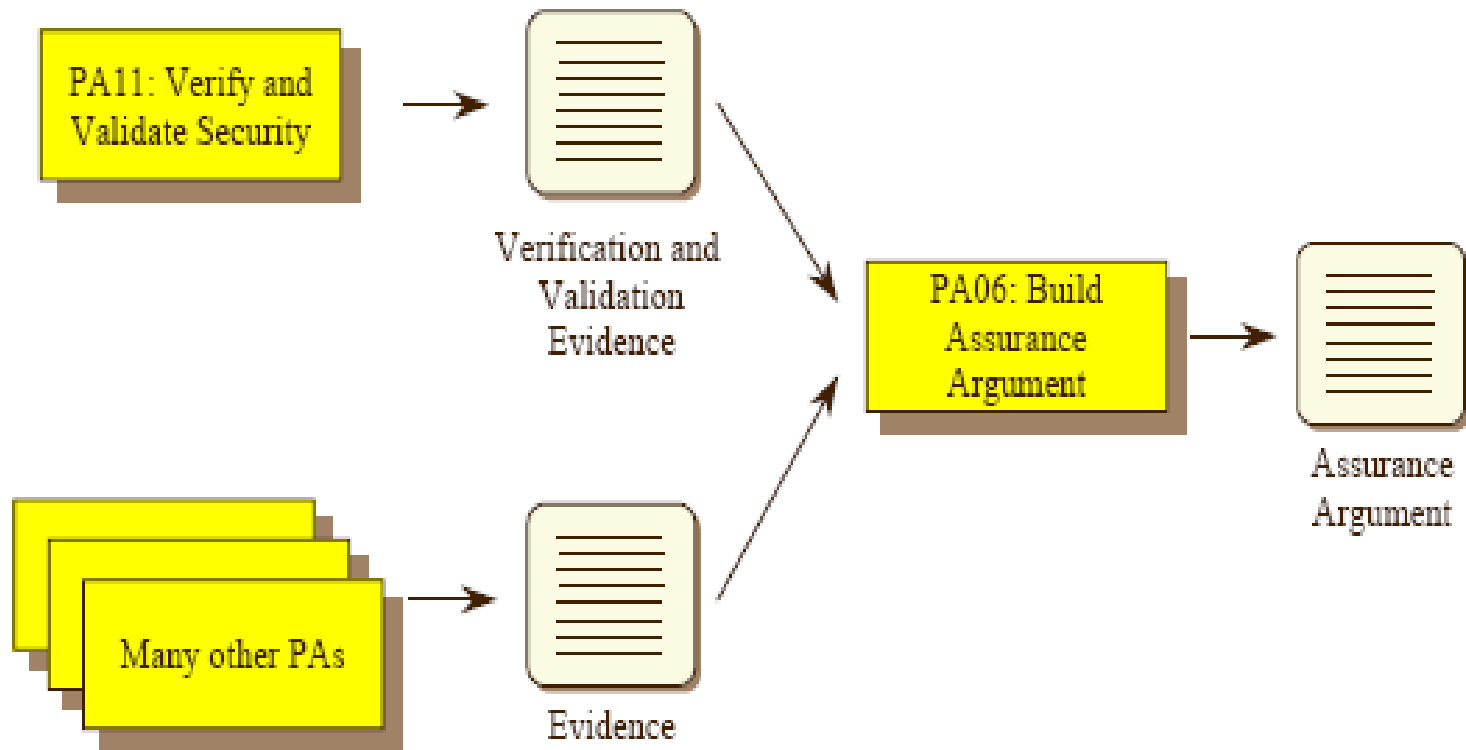
# Security is part of Engineering

---



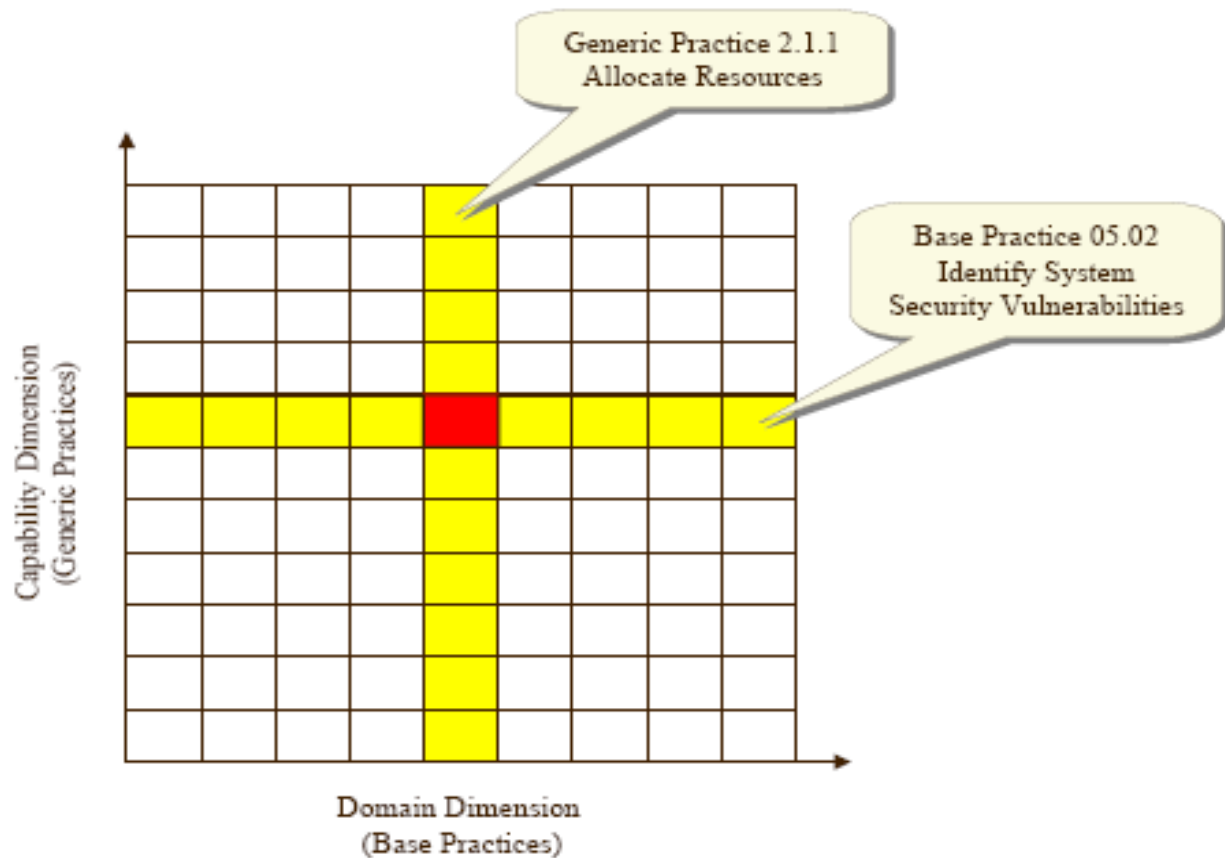
# Assurance

---





# SSE-CMM dimensions



Practices (generic) that indicate Process Management & Institutionalization Capability

# SSE-CMM

---

- 129 base practices **organized** into 22 process areas
  - 61 of these, organized in 11 process areas, cover all major areas of **security engineering**
  - Remaining relates to **project** and **organization** domains
- Base practice
  - Applies across the life cycle of the enterprise
  - Does not overlap with other base practices
  - Represents a “best practice” of the security community
  - Does not simply reflect a state of the art technique
  - Is applicable using multiple methods in multiple business context
  - Does not specify a particular method or tool

## Process Area

---

- Assembles related activities in one area for ease of use
- Relates to valuable security engineering services
- Applies across the life cycle of the enterprise
- Can be implemented in multiple organization and product contexts
- Can be improved as a distinct process
- Can be improved by a group with similar interests in the process
- Includes all base practices that are required to meet the goals of the process area

# Process Areas

---

## Process Areas related to Security Engineering process areas

- PA01 Administer Security Controls
- PA02 Assess Impact
- PA03 Assess Security Risk
- PA04 Assess Threat
- PA05 Assess Vulnerability
- PA06 Build Assurance Argument
- PA07 Coordinate Security
- PA08 Monitor Security Posture
- PA09 Provide Security Input
- PA10 Specify Security Needs
- PA11 Verify and Validate Security

## Process Areas related to project and Organizational practices

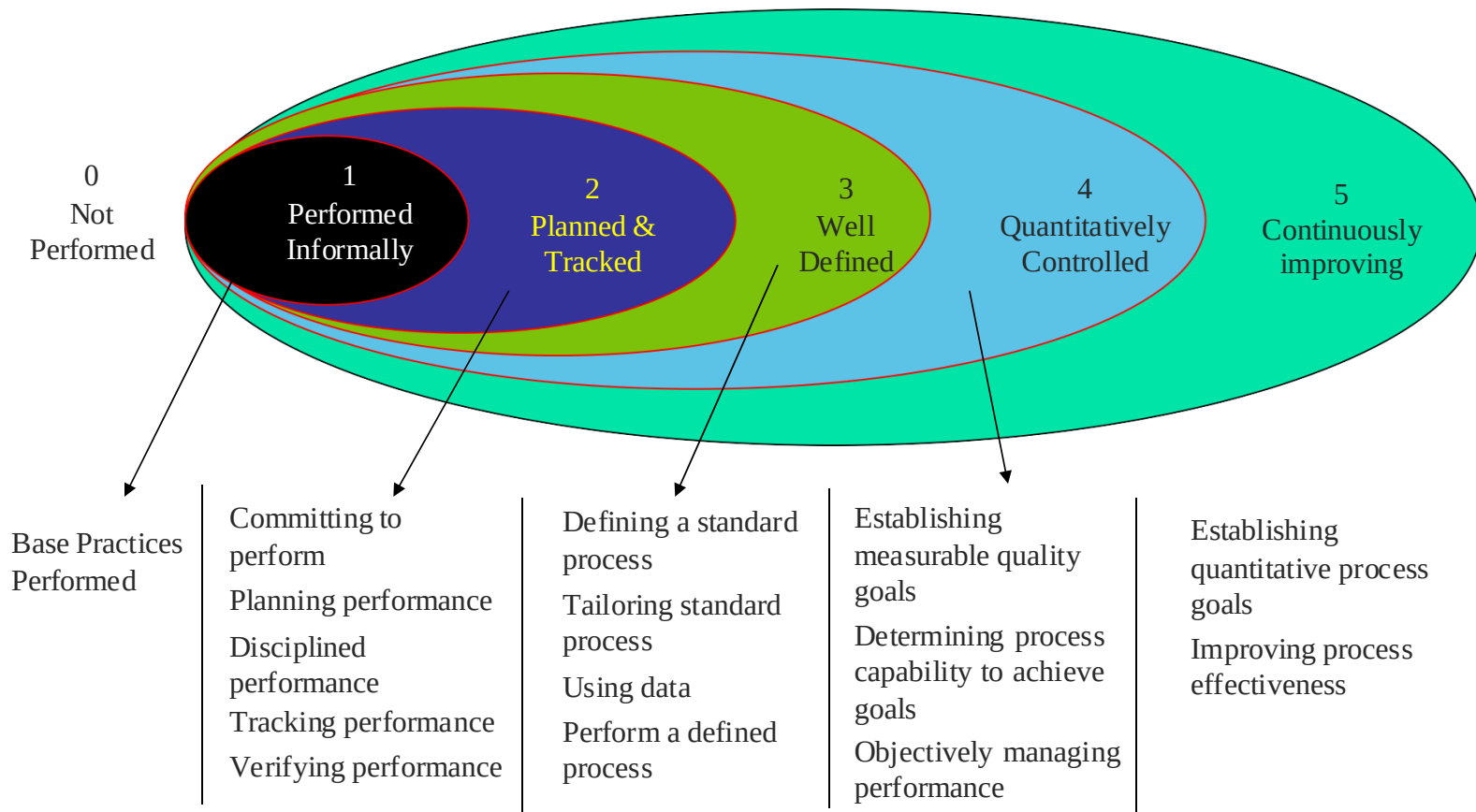
- PA12 – Ensure Quality
- PA13 – Manage Configuration
- PA14 – Manage Project Risk
- PA15 – Monitor and Control Technical Effort
- PA16 – Plan Technical Effort
- PA17 – Define Organization's Systems Engineering Process
- PA18 – Improve Organization's Systems Engineering Process
- PA19 – Manage Product Line Evolution
- PA20 – Manage Systems Engineering Support Environment
- PA21 – Provide Ongoing Skills and Knowledge
- PA22 – Coordinate with Suppliers

## Generic Process Areas

---

- Activities that apply to all processes
- They are used during
  - Measurement and institutionalization
- Capability levels
  - Organize common features
  - Ordered according to maturity

# Capability Levels



## Summary chart

[illegible]

# Using SSE-CMM

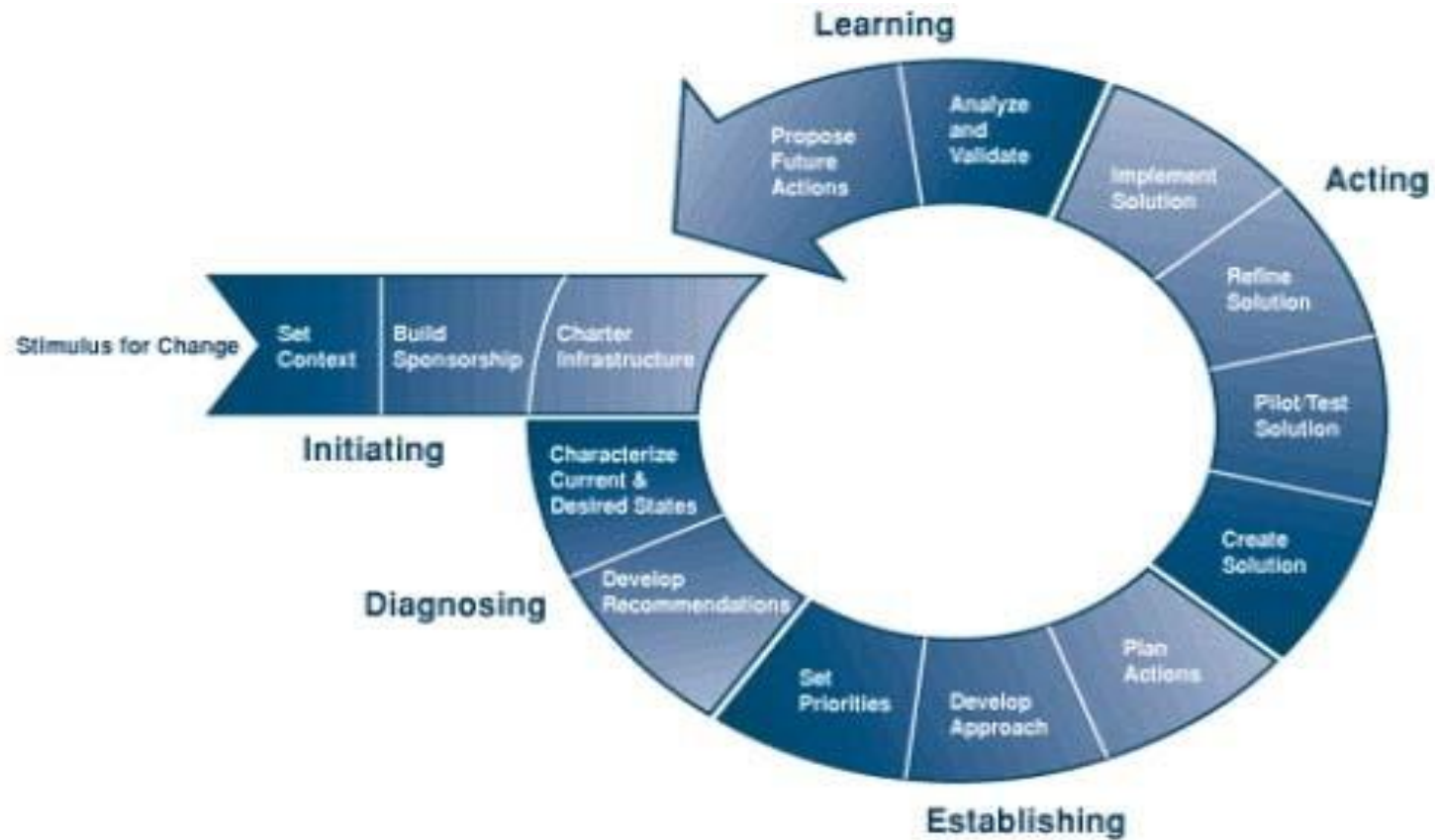
---

- Can be used in one of the three ways
  - Process improvement
    - Facilitates understanding of the level of security engineering process capability
  - Capability evaluation
    - Allows consumer organization to understand the security engineering process capability of provider
  - Assurance
    - Increases the confidence that product/system/service is trustworthy



# Process Improvement

---



# Capability Evaluation

---

- No need to use any particular appraisal method developed if needed
- SSE-CMM Appraisal (SSAM) method has been developed if needed
- SSAM purpose
  - Obtain the baseline or benchmark of actual practice related to security engineering within the organization or project
  - Create or support momentum for improvement within multiple levels of the organizational structure

# SSAM Overview

---

- Planning phase
  - Establish appraisal framework
- Preparation phase
  - Prepare team for onsite phase through information gathering (questionnaire)
  - Preliminary data analysis indicate what to look for / ask for
- Onsite phase
  - Data gathering and validation with the practitioner
  - interviews
- Post-appraisal
  - Present final data analysis to the sponsor

# Capability Evaluation

|                   |               |                                    |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|-------------------|---------------|------------------------------------|------|------|------|------|------|------|------|------|------|------------------------------------------|------|------|------|------|------|------|------|------|------|------|------|--|
| Capability Levels | Process Areas | Level 5                            |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|                   |               | Level 4                            |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|                   |               | Level 3                            |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|                   |               | Level 2                            |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|                   |               | Level 1                            |      |      |      |      |      |      |      |      |      |                                          |      |      |      |      |      |      |      |      |      |      |      |  |
|                   |               | PA01                               | PA02 | PA03 | PA04 | PA05 | PA06 | PA07 | PA08 | PA09 | PA10 | PA11                                     | PA12 | PA13 | PA14 | PA15 | PA16 | PA17 | PA18 | PA19 | PA20 | PA21 | PA22 |  |
|                   |               | Security Engineering Process Areas |      |      |      |      |      |      |      |      |      | Project and Organizational Process Areas |      |      |      |      |      |      |      |      |      |      |      |  |

# Assurance

---

- A mature organization
  - more likely to create a product or system with appropriate assurance
- Process evidence
  - to support claims for the product trustworthiness
- It is conceivable that
  - an **immature** organization could produce high assurance product.

## CMI/iCMM/SSE-CMM

---

- CMMI / iCMM used by more organizations than the SSE-CMM
  - Because of the integration of process disciplines and coverage of enterprise issues,
- One weakness CMMI and iCMM
  - have gaps in their coverage of safety and security.
- Joint effort sponsored by FAA and the DoD
  - to identify **best safety and security practices** for use in combination with the iCMM and the CMMI.

## Safety/Security additions

---

- The proposed Safety and Security additions include the following four goals:
  - Goal 1 – An infrastructure for safety and security is established and maintained.
  - Goal 2 – Safety and security risks are identified and managed.
  - Goal 3 – Safety and security requirements are satisfied.
  - Goal 4 – Activities and products are managed to achieve safety and security requirements and objectives.

## Goal 1 related practices

---

1. Ensure safety and **security awareness**, guidance, and competency.
2. Establish and maintain a **qualified work environment** that meets safety and security needs.
3. Ensure integrity of information by providing for its **storage and protection**, and **controlling access** and distribution of information.
4. **Monitor, report and analyze** safety and security **incidents** and identify potential corrective actions.
5. Plan and provide for **continuity of activities** with contingencies for threats and hazards to operations and the infrastructure

**Goal 1 – An infrastructure for safety and security is established and maintained.**



## Goal 2 related practices

---

1. **Identify risks** and sources of risks attributable to **vulnerabilities**, security **threats**, and safety **hazards**.
2. For each risk associated with safety or security, determine the causal **factors**, estimate the consequence and **likelihood** of an occurrence, and determine relative priority.
3. For each risk associated with safety or security, determine, implement and monitor the **risk mitigation** plan to achieve an acceptable level of risk.

Goal 2 – Safety and security risks are identified and managed.

## Goal 3 related practices

---

1. Identify and document applicable **regulatory** requirements, laws, standards, policies, and acceptable levels of safety and security.
2. Establish and maintain **safety and security requirements**, including integrity levels, and design the product or service to meet them.
3. Objectively **verify** and validate work and delivered products and services to assure safety and security requirements achieved and fulfill intended use.
4. Establish and maintain safety and security **assurance** arguments and supporting evidence throughout the lifecycle.

**Goal 3 – Safety and security requirements are satisfied.**

## Goal 4 related practices

---

1. Establish and maintain **independent reporting** of safety and security status and issues.
2. Establish and maintain a **plan to achieve** safety and security requirements and objectives.
3. **Select and manage products** and suppliers using safety and security criteria.
4. **Measure, monitor and review** safety and security activities against plans, control products, take corrective action, and improve processes.

Goal 4 – Activities and products are managed to achieve safety and security requirements and objectives.

# Team Software Process for Secure SW/Dev

- TSP
  - provides a framework, a set of processes, and disciplined methods for applying software engineering principles at the team and individual level
- TSP for Secure Software Development (TSP-Secure)
  - focus more directly on the security of software applications.

## Team Software Process for Secure SW/Dev

- TSP-Secure addresses secure software development (three ways).
  1. Secure software is not built by accident,
    - **Plan**: TSP-Secure addresses planning for security.
    - **Self-direct**: Since schedule pressures and people issues get in the way of implementing best practices, TSP-Secure helps to build **self-directed development teams**, and then put these teams in charge of their own work.
  2. Since security and quality are closely related,
    - TSP-Secure helps manage **quality** throughout the product development life cycle.
  2. Since people building secure software must have an awareness of software security issues,
    - TSP-Secure includes **security awareness training for developers**.

## ■ Teams

- Develop their own plans
- Make their own commitments
- Track and manage their own work
- Take corrective action when needed

# TSP-Secure

---

- Initial planning – “project launch” (3-4 days)
  - Tasks include
    - identifying security risks,
    - eliciting and defining security requirement, secure design, and code reviews,
    - use of static analysis tools, unit tests, and Fuzz testing.
- Next, the team executes its plan, and ensures all security related activities are taking place.
  - Security status is presented and discussed during every management status briefing.

## ■ Basis

- Defective software is seldom secure
- Defective software is not inevitable
  - Consider cost of reducing defects
  - Manage defects throughout the lifecycle
- Defects are leading cause of vulnerabilities
  - Use multiple defect removal points in the SD
    - Defect filters



- Key questions in managing defects
  - What type of defects lead to security vulnerabilities?
  - Where in the software development life cycle should defects be measured?
  - What work products should be examined for defects?
  - What tools and methods should be used to measure the defects?
  - How many defects can be removed at each step?
  - How many estimated defects remain after each removal step?
- TSP-Secure includes training for developers, managers, and other team members.

# TSP-Secure

